

Cyber Tabletop Exercise

Core Banking Vendor Compromise

Scenario source: Generated from uploaded STIX bundle describing a third-party core banking SaaS compromise affecting downstream banking operations.

Classification: Internal use for exercise purposes only

Recommended duration: 75–90 minutes

Audience: Executive, operational, technical, legal/compliance, communications, third-party risk, business continuity

1. Exercise Overview

This tabletop exercise simulates a cyber incident originating from a third-party core banking SaaS provider that supports account servicing and loan management workflows. A malicious compromise of the vendor's software update channel results in service disruption, uncertainty about downstream exposure, and a difficult decision about when and how to reconnect the affected platform.

The exercise is designed to test incident response, crisis coordination, service continuity, third-party assurance, customer communications, and decision-making under uncertainty.

2. Background Context

The participating bank relies on a vendor-managed **loan servicing and account management platform** for key customer servicing functions. The platform is used by branch and call-center personnel to support account maintenance, payment arrangements, hardship workflows, and other servicing activities.

A cyber incident at the vendor has affected the software update process used to maintain the platform. As a result, the bank must determine the scope of operational impact, contain risk from the third-party dependency, and continue serving customers through manual alternatives while evaluating whether the vendor's environment is sufficiently trustworthy for reconnection.

Assumptions used to expand the scenario

- The bank has network integrations with the vendor-hosted servicing platform.
- The platform is important to day-to-day customer servicing but is not the sole system of record for all banking operations.
- The primary customer impact is on account servicing, hardship handling, and loan/account administration through branch and contact-center channels.
- No confirmed bank-side data compromise is known at exercise start.
- Regulatory, legal, and customer-notification decisions depend on what is later confirmed.

3. Exercise Objectives

By the end of the exercise, participants should be able to:

1. Demonstrate clear escalation and crisis governance for a material third-party cyber incident.
 2. Assess operational impact when a vendor-hosted servicing platform becomes unavailable.
 3. Decide how and when to isolate vendor-integrated services from the bank network.
 4. Execute customer servicing workarounds and prioritize critical customer needs.
 5. Evaluate assurance requirements before reconnecting a previously isolated third-party service.
 6. Coordinate internal and external communications, including leadership, customers, regulators, and the vendor.
 7. Identify legal, compliance, and post-incident reporting considerations.
 8. Capture lessons learned for resilience, vendor governance, and recovery criteria.
-

4. Scope

In scope

- Third-party cyber incident response
- Crisis management and escalation
- Business continuity and manual fallbacks
- Vendor risk and assurance
- Customer communications
- Technology containment and reconnection decisions
- Legal, compliance, and regulatory considerations
- Post-incident review and remediation

Out of scope

- Deep forensic analysis of the vendor environment
 - Live technical recovery actions in production
 - Contractual dispute resolution in detail
 - Full legal advice specific to any one jurisdiction
-

5. Participant Roles

Executive / Crisis leadership

- Country or business leadership
- Crisis management lead
- Chief information security leadership
- Operations leadership

Operational stakeholders

- Branch operations
- Contact center / customer servicing
- Loan servicing operations
- Business continuity lead
- Third-party risk management

Technical stakeholders

- Security operations / incident response
- Infrastructure and network teams
- IAM / access management
- Enterprise architecture / integration owners
- Application support

Control functions

- Legal
 - Compliance
 - Privacy
 - Internal communications
 - External communications / media
 - Regulatory affairs
-

6. Rules of Engagement

- This is a no-fault exercise intended to identify strengths and improvement areas.
 - Participants should respond based on current roles, authorities, and processes.
 - Real incidents take precedence over the exercise.
 - Assume the scenario is real unless the facilitator states otherwise.
 - Participants should not solve the scenario by assuming facts not yet provided.
 - The facilitator may add details if discussion stalls.
-

7. Scenario Summary

A core banking SaaS provider used by the bank for account servicing and loan-management workflows suffers a cyber incident involving compromise of its software update channel. The provider notifies customers of the incident and warns of service instability. The bank begins experiencing loss of account-servicing capability in branch and call-center channels.

As the incident develops, the bank must isolate the vendor-connected service, activate manual servicing procedures, manage customer impact, and determine whether the provider's claims of remediation are sufficient to justify reconnection. The central tension in the exercise is not only containment, but trust

restoration: **what minimum evidence is needed before reconnecting a critical third-party service to the bank environment?**

8. Exercise Timeline and Injects

Inject 1 – Vendor advisory and degraded servicing

Exercise time: 09:00

Situation

The core banking SaaS provider notifies customers that it is responding to an ongoing cyber incident associated with a software update. Shortly afterward, the bank experiences disruption in account-servicing functions used by branch and call-center teams. Staff report that they cannot reliably perform account maintenance, hardship processing, and certain loan-servicing actions through the usual platform.

What participants know

- The vendor has acknowledged a cyber incident.
- The issue is linked to the vendor's software update process.
- The bank is experiencing loss or degradation of customer-servicing functions.
- The duration and scope of the incident remain unclear.
- No confirmed evidence yet indicates compromise inside the bank environment.

Discussion questions

- What is the initial severity assessment, and who owns it?
- What immediate containment, monitoring, and triage actions should be initiated?
- Which customer-facing services are critically affected?
- Which servicing activities must be prioritized in the first two hours?
- What workarounds are available for branch and contact-center staff?
- Who must be informed internally in the first 30–60 minutes?
- What facts must be obtained from the vendor immediately?

Expected actions

- Open and classify the incident.
- Activate third-party incident escalation procedures.
- Identify business processes dependent on the affected platform.
- Confirm whether integrations should be restricted or monitored more closely.
- Stand up manual fallback procedures for urgent customer needs.
- Establish a bank-side information requirement list for the vendor.

Facilitator notes

Look for whether participants separate **operational outage management** from **cyber containment** while coordinating both. Strong responses should identify urgent customer-impact categories such as hardship requests, payment arrangements, delinquency servicing, complaint handling, vulnerable-customer support, and time-sensitive account actions.

Sample evidence requests to the vendor

- Nature of the incident and current status
 - Whether customer tenants are logically isolated
 - Whether malicious code was distributed through the update mechanism
 - Whether indicators of compromise or detection logic are available
 - Whether the vendor recommends customer-side containment measures
 - Expected recovery timeline and service-restoration dependencies
-

Inject 2 – Bank-side isolation and sustained disruption

Exercise time: 12:00

Situation

Following additional internal risk review, the bank decides to isolate vendor-integrated connections until reconnection criteria can be assessed. Manual servicing is now in effect for priority cases. Queue times are rising in call centers, branch staff are escalating exceptions, and business leaders want to understand how long core servicing can continue in manual mode without creating customer harm or control failures.

What participants know

- The vendor service remains unstable or unavailable.
- The bank has isolated or suspended integrations with the vendor platform.
- Manual servicing is underway.
- Customer backlogs are building.
- There is still no clear vendor recovery ETA.

Discussion questions

- Who has authority to isolate or maintain isolation of the vendor-integrated service?
- What monitoring should be enhanced while the platform remains disconnected?
- How will high-risk or high-priority customer cases be handled?
- What compensating controls are required for manual servicing?
- What is the threshold for escalating to a formal crisis-management structure?
- What are the communications to frontline teams, senior management, and relationship managers?
- Are any regulatory notifications triggered by disruption alone?

Expected actions

- Maintain containment of vendor-connected services.
- Track critical service impacts, backlog growth, and control exceptions.
- Activate an approved manual operating procedure with segregation of duties.
- Define customer-priority tiers and exception-routing paths.
- Record decisions, risk acceptance, and temporary control changes.
- Coordinate internal messaging to avoid inconsistent communications.

Facilitator notes

Push participants on how they preserve control quality during manual operations. Good answers should address maker-checker controls, approval overrides, call recording, audit trails, exception logs, customer vulnerability handling, and workload prioritization.

Inject 3 – Vendor claims remediation complete

Exercise time: Day 2, 10:00

Situation

The vendor states that remediation is complete and that services are ready to be restored. However, the bank must decide whether to reconnect immediately, require additional evidence, or continue isolation while manual servicing persists. The vendor provides a short customer notice stating that the issue has been contained and normal service can resume.

What participants know

- The vendor says the threat has been mitigated.
- The bank has not yet independently validated safe reconnection.
- Manual servicing remains operational but strained.
- Senior business leaders are pressing for restoration to reduce customer harm and operational backlog.

Decision point

Should the bank reconnect now, reconnect conditionally, or remain isolated pending further assurance?

Discussion questions

- What minimum assurance is required before reconnection?
- Which teams must sign off on reconnection?
- What evidence from the vendor is necessary and sufficient?
- Is additional technical validation needed on the bank side before restoring connectivity?
- What are the risks of reconnecting too early versus staying disconnected too long?

- How should the bank communicate the decision to staff, customers, and regulators?

Expected actions

- Define formal reconnection criteria.
- Require vendor evidence before trust is restored.
- Assess bank-side exposure, logs, endpoint telemetry, and integration pathways.
- Use a staged or conditional reconnection approach if appropriate.
- Preserve executive decision records and rationale.

Facilitator notes

This is the core governance moment of the exercise. Participants should not treat vendor restoration claims as automatically sufficient. Strong responses typically require a combination of:

- incident summary and root-cause statement,
- timeline of containment and eradication,
- assurance that malicious updates or persistence mechanisms were removed,
- evidence of environment validation and integrity checks,
- customer impact assessment,
- indicators or detections for downstream customers,
- confirmation of monitoring enhancements,
- named authority from the vendor for attestation.

Suggested reconnection criteria

- Formal vendor incident declaration and remediation summary received
- Clear statement on whether customer environments or data were impacted
- Relevant indicators of compromise reviewed by bank security teams
- No evidence of malicious activity in bank logs related to the integration
- Compensating monitoring in place for at least an initial burn-in period
- Business and security sign-off documented
- Rollback or re-isolation plan prepared before reconnection

Inject 4 – Controlled restoration and after-action obligations

Exercise time: Day 3, 09:00

Situation

After completing validation steps, the bank restores the vendor-connected platform in a controlled manner. Core account-servicing functions are returning to normal, but significant backlog remains. Leadership requests a post-incident review covering operational impact, customer harm, vendor performance, and improvements to third-party cyber resilience.

What participants know

- Connectivity has been restored under enhanced monitoring.
- Priority servicing is stabilizing, but backlog clearance will take time.
- The incident has raised questions about vendor governance, dependency concentration, and recovery criteria.
- Post-incident reporting obligations may apply.

Discussion questions

- What must happen in the first 24–72 hours after restoration?
- How should customer backlog and service recovery be prioritized?
- What notifications, reports, or board-level briefings are required?
- What contractual, third-party risk, or assurance issues should be reviewed with the vendor?
- What strategic improvements are needed to reduce concentration risk and improve resilience?

Expected actions

- Maintain heightened monitoring for a defined observation period.
- Validate data integrity, transaction completeness, and backlog disposition.
- Conduct internal debrief and collect evidence for reporting.
- Review third-party risk controls, escalation clauses, and assurance requirements.
- Update crisis playbooks, reconnection protocols, and manual fallback procedures.

Facilitator notes

Good responses should move beyond technical restoration and address resilience improvements, such as vendor assurance language, dependency mapping, manual fallback maturity, tabletop frequency, recovery testing, and customer-impact metrics.

9. Facilitator Prompt Bank

Use these prompts if discussion slows:

- What is the single most important decision in the first hour?
 - Which customer populations would be harmed most by prolonged servicing disruption?
 - How do you distinguish business urgency from security assurance?
 - What evidence would make you comfortable reconnecting?
 - What if the vendor refuses to share detailed forensics?
 - What if regulators ask why the bank trusted the vendor's statement?
 - What if manual servicing causes a spike in complaints or control exceptions?
 - What would executives want to know every two hours during the disruption?
-

10. Executive View

Executives should focus on:

- Customer harm and reputational exposure
- Decision authorities and escalation thresholds
- Regulatory and board visibility
- Trade-off between service restoration and residual cyber risk
- Third-party dependency and concentration risk
- Documented risk acceptance and governance discipline

Executive decision themes

- Whether to declare a formal crisis
 - Whether to isolate vendor-linked services
 - What customer communications are needed
 - Whether vendor evidence is enough to reconnect
 - What strategic remediation should be mandated post-incident
-

11. Operational View

Operational teams should focus on:

- Manual servicing workflows
- Prioritization of urgent customer cases
- Call-center and branch guidance
- Exception handling and control preservation
- Backlog management and customer communications
- Recovery sequencing once service is restored

Examples of priority servicing categories

- Vulnerable or hardship customers
 - Time-sensitive payment arrangements
 - Account blocks or fraud-related servicing
 - Regulatory or complaints-driven deadlines
 - High-value customer commitments requiring same-day handling
-

12. Technical View

Technical teams should focus on:

- Isolation of third-party integrations
- Monitoring of bank-side telemetry for related IOCs

- Integrity validation and log review
- Reconnection gating and staged restoration
- Short-term compensating controls
- Evidence preservation for post-incident analysis

Technical decision considerations

- Which interfaces, APIs, credentials, or network paths are affected?
 - Are service accounts, API keys, tokens, or certificates at risk?
 - Can the service be restored in read-only or limited mode first?
 - What rollback options exist if suspicious behavior resumes?
-

13. Communications Considerations

Internal communications

- Situation status and impact summary
- Approved talking points for frontline staff
- Escalation path for exceptions
- Frequency of leadership updates

External communications

- Customer notices if service degradation becomes material
- Messaging to critical partners or outsourcers
- Regulator communications if required
- Media holding statements if the incident becomes public

Key messaging principles

- Acknowledge service impact without speculating
 - Avoid promising timelines not yet confirmed
 - Distinguish vendor statements from bank-validated facts
 - Keep customer guidance practical and consistent
-

14. Success Criteria

The exercise is successful if participants:

- Escalate the incident appropriately and quickly.
- Identify critical dependencies and impacted services.
- Make a clear containment decision for the vendor-integrated platform.
- Implement workable manual servicing with compensating controls.
- Define concrete reconnection criteria rather than relying on vendor assurances alone.
- Coordinate business, technical, legal, and communications functions effectively.

- Identify practical resilience improvements for third-party cyber events.
-

15. Debrief Questions

1. What worked well in the response model?
 2. Where were decision authorities unclear?
 3. Did the organization have enough visibility into third-party dependencies?
 4. Were manual workarounds realistic and controlled?
 5. Was the threshold for safe reconnection clearly understood?
 6. Which stakeholders were engaged too late or not at all?
 7. What would improve customer-outcome management during sustained disruption?
 8. Which control, contractual, or architecture changes should be prioritized next?
-

16. Recommended Improvement Areas

- Stronger inventory and classification of critical third-party service dependencies
 - Better-defined isolation and reconnection playbooks for vendor-originated cyber incidents
 - Preapproved manual servicing procedures with control overlays
 - Tighter assurance requirements in vendor contracts and incident-notification clauses
 - Faster access to integration maps, service accounts, and dependency owners
 - Stronger customer-impact metrics for service continuity decisions
 - Clearer regulator and customer communication templates for third-party incidents
 - Periodic testing of recovery from vendor-side cyber disruptions
-

17. MITRE ATT&CK Mapping

This mapping reflects behaviors represented in the scenario and is intended for exercise design rather than forensic attribution.

Likely tactics represented

- Initial Access
- Persistence
- Defense Evasion
- Command and Control
- Impact
- Discovery

Relevant techniques and sub-techniques

T1195.002 – Supply Chain Compromise: Compromise Software Supply Chain

Most directly reflected by compromise of the vendor's software update channel.

T1199 – Trusted Relationship

Reflected by risk propagation through the bank's trusted dependency on a third-party SaaS provider.

T1078 – Valid Accounts

Potentially relevant if legitimate vendor or service accounts are used during malicious update deployment or downstream access.

T1133 – External Remote Services

Potentially relevant where vendor-hosted administrative or integration pathways connect into the bank environment.

T1489 – Service Stop

Reflected indirectly through disruption and suspension of account-servicing capabilities.

T1562 – Impair Defenses

Potentially relevant if the compromised update path bypasses trust assumptions or weakens visibility.

T1499 – Endpoint Denial of Service / Service-level disruption considerations

Not necessarily literal DoS, but operational unavailability is central to the scenario's business impact.

T1584 / resource-development-style preparation considerations

Less central to the exercise, but relevant if adversary preparation of vendor infrastructure is discussed.

ATT&CK interpretation note

The exercise centers on a supply-chain-style compromise that creates downstream operational impact and a trust-restoration problem for the bank. The most important ATT&CK concepts are therefore **software supply chain compromise**, **trusted relationship abuse**, and **service disruption / restoration governance**.

18. Source-to-Scenario Traceability

The exercise was derived from the uploaded STIX content describing:

- a banking organization dependent on a third-party core servicing provider,
 - an attack pattern involving compromise of a third-party software update channel,
 - an incident involving vendor-originated disruption of the core servicing platform,
 - an initial inject covering vendor notification and degraded account servicing,
 - a second inject centered on the safe reconnection decision,
 - and courses of action covering temporary disconnection and manual customer servicing fallback.
-

19. Optional Layout / Visual Suggestions for PDF

- Cover page with title, scenario subtitle, and confidentiality marking
- One-page scenario overview graphic showing bank ↔ vendor dependency
- Timeline page with four injects and decision gates
- Color-coded callout boxes for executive, operational, and technical discussion points
- Final appendix containing MITRE ATT&CK mapping and improvement tracker